

Fintap Production Readiness Audit and Remediation Record

Zynotch PVT Limited | Application: Billing Brilliance / Fintap | Review date: 5 September 2026 | Repository assessment only

Executive decision

Status: CONDITIONALLY READY FOR CONTROLLED UAT; NOT YET APPROVED FOR PRODUCTION CUTOVER.

The reviewed code now clears its available static quality gates and the major application defects identified in the audit have been remediated. The school-facing data views and bulk workflows no longer depend on downloading or processing the complete student population in the browser. The organization experience has been reduced to an API integration portal. API-key rotation now has an explicit typed confirmation at both the interface and server. The 1BILL inquiry and payment path has stricter validation, tenant isolation, duplicate protection, transaction boundaries, and production network controls.

This statement does not mean app.fintap.com was deployed or changed. No production credentials, host access, database, reverse proxy, certificate, firewall, SFTP account, or 1LINK UAT environment was available in this workspace. Production cutover remains blocked until the external gates in this report are completed and evidenced.

Scope and evidence

Reviewed areas included the React/Vite application, Express API, MySQL data access and migrations, authentication and authorization, school workflows, organization API portal, API-key lifecycle, webhook behavior, 1BILL REST endpoints, configuration, dependencies, tests, and the supplied 1LINK documents.

Authoritative integration references used:

- 1LINK Generic REST Based Specification v1.5 supplied in docs/1Link.
- 1LINK Data Network Guidelines and Standards supplied in docs/1Link.
- 1BILL Aggregator Overview supplied in docs/1Link.
- Kickoff Minutes of Meeting dated 4 September 2026 supplied by Zynotch.

Remediation summary

Scalability and product fit

Area	Change made	Decision reason	Result
Student directory	Added server-side pagination, search, class, section, status, defaulter, scholarship, and risk filtering with facets and aggregate dues.	A browser must not load the entire population to render a page.	Page work is bounded as enrolment grows beyond 2,000.
Defaulters and invoices	Replaced full-population joins in the browser with paginated server queries and financial aggregates.	Large client-side joins increase memory, latency, and failure risk.	Views return only the requested page and metadata.
Dashboards and reports	Replaced full student, invoice, and history downloads with database aggregates; corrected collection-by-plan over-counting.	Reporting should be computed once near the data and must not multiply payments through assignments.	Lower payloads and more reliable totals.
Monthly generation	Preloads existing invoices, balances, scholarships, and transport charges; builds rows in memory; performs bulk inserts in one tenant-serialized transaction.	The old flow issued several queries per student and could partially complete a large run.	Database round-trips are approximately constant and invoices/ledger rows commit atomically.
Bulk plan and scholarship assignment	Added bounded server search and single transactional bulk APIs for class or selected-student operations.	Thousands of browser requests would hit rate limits and leave partial assignments.	A 2,000-student class is handled as one controlled request and transaction.
Invoice numbering	Uses a tenant row lock and the current maximum sequence for manual and batch creation.	COUNT-based numbering can collide after deletion or concurrent requests.	Concurrency-safe tenant invoice sequences.
Frontend delivery	Lazy-loaded application routes and retained page-level loading fallback.	The previous single bundle delayed every role and page.	Production build emits small route chunks; current main application chunk is about 222 KB before gzip.
Organization portal	Removed invoice, payment, history, real-time, report, and sandbox routes/navigation from the organization role. Reframed the dashboard around API status, endpoints, credentials, webhook, IP allowlist, and security activity.	The organization tenant is an API consumer, not an operational payment dashboard.	Smaller, clearer API-only experience with unused pages excluded from the bundle.

Access and 1BILL contract

Area	Change made	Decision reason	Result
API-key rotation	Added destructive confirmation dialogs requiring REGENERATE plus the exact biller ID or PCID; repeated the check on the server; used cryptographic random keys; wrote an audit event.	Rotation invalidates the old key immediately and must resist accidental clicks or direct API calls.	Two-layer confirmation and auditable rotation.
Authentication	Restored sessions from the server profile, prevented false initial authentication, allowed authenticated tenant API keys through school-role authorization, and disabled profile caching.	The previous refresh behavior and API-key role path could produce incorrect access results.	More consistent session and API authentication.
1BILL identifiers	Generates standard 20-digit numeric consumer numbers from the assigned prefix, biller code, and locked sequence; accepts controlled custom numeric values up to 24 digits for required UAT cases.	Align normal issuance with the 1LINK note while supporting the requested 24-digit test case.	Predictable unique numbers without random collisions.
Bill inquiry	Validates consumer number, bank mnemonic, and reserved length; handles inactive/blocked accounts; applies late fee only when overdue; pads fixed fields.	Gateway contracts require deterministic field lengths and status semantics.	More specification-aligned inquiry responses.
Bill payment	Validates fixed fields and exact payable amount; locks the payer/invoice; writes payment, transaction, invoice, ledger, and organization records in a database transaction; commits before audit; protects duplicate references.	Financial state cannot be partially written or double-posted.	Atomic posting and safer retries.
Tenant isolation	Tied bundle/PCID lookup to the student's tenant and applied tenant filters to relevant data paths.	A bundle from another biller must never price a consumer.	Reduced cross-tenant exposure risk.

Perimeter and operations

Area	Change made	Decision reason	Result
1LINK edge security	Production source-IP allowlist, constant-time credential comparisons, dedicated rate limit, correct payment-shaped authentication errors, and fail-closed startup configuration.	Internet-facing payment endpoints require layered authentication and predictable responses.	Requests can be restricted to approved 1LINK addresses.
HTTPS and configuration	Production refuses to start with default JWT secrets, missing database credentials, demo 1LINK credentials, empty 1LINK allowlist, invalid six-digit prefix, unsafe webhook secret, or disabled HTTPS enforcement.	A deployment should fail visibly instead of silently running insecurely.	Misconfiguration becomes a startup failure.
Webhooks	Enforced public HTTPS port 443 URLs, rejected credentials/local/private destinations after DNS resolution, revalidated before delivery, used HMAC signatures and constant-time callback verification, and stopped logging full callback URLs.	Prevent server-side request forgery, secret leakage, and spoofed callbacks.	Safer outbound notifications and inbound verification.
Operations	Added unauthenticated liveness and database-backed readiness endpoints; placed gateway routes before broad authenticated routers; prevented tests from starting a listener.	Orchestrators need distinct liveness/readiness and tests need isolated imports.	Better deployment health behavior and testability.
Dependencies and tests	Updated supported packages, separated database integration tests, and added unit/smoke tests for URL safety, health, and 1BILL authentication response shape.	Known package vulnerabilities and untestable startup paths are production risks.	Root and server audits report zero known vulnerabilities.

Verification record

Check	Result on 5 September 2026	Notes
TypeScript	PASS	npx tsc --noEmit completed successfully.
Frontend production build	PASS	Vite 8.2.2 transformed 2,356 modules and emitted route-level chunks.
Frontend tests	PASS	1 of 1 Vitest test passed.
Server tests	PASS	13 of 13 Jest unit/smoke tests passed across 2 suites.
JavaScript syntax	PASS	node --check completed for server source and unit tests.
ESLint	PASS WITH WARNINGS	0 errors; 7 Fast Refresh warnings in shared UI component modules.
Dependency audit	PASS	npm audit and npm audit --omit=dev reported 0 vulnerabilities in root and server packages.
Patch hygiene	PASS	git diff --check reported no whitespace errors.
Live database integration	NOT EXECUTED	Requires a disposable MySQL instance and representative data.
2,000+ load test	NOT EXECUTED	Architecture was remediated; measured latency and capacity still require staging data.
1LINK UAT/certification	NOT EXECUTED	Requires 1LINK network access, credentials, test consumers, and sign-off.

Key decisions and trade-offs

Server pagination instead of a larger browser limit

Increasing a client limit from 2,000 to a larger number only postpones failure. Search, filtering, counts, financial totals, and facets are now server responsibilities; the browser receives a bounded page. Export actions intentionally export the visible page unless a controlled asynchronous export service is added later.

Transactional bulk operations instead of request fan-out

Class assignment and monthly generation are business operations, not UI loops. They now run as tenant-serialized transactions with bulk database writes. This prevents rate-limit failures and makes a run all-or-nothing. Very large future tenants should move these operations to a queued job with progress and idempotency keys.

Typed key-rotation confirmation

A generic Yes button is inadequate for an irreversible secret rotation. The user must type a target-specific phrase, and the server independently verifies it. Existing plaintext API-key display is preserved for compatibility, but one-time secret display plus hashing/encryption at rest is recommended as a subsequent security change.

API-only organization experience

Operational finance screens were removed from organization routing and navigation because the agreed consumer is an API client. Webhook configuration, API security, source-IP restrictions, login activity, and reference endpoints remain because they directly support integration and audit needs.

Specification conflicts are not guessed

The supplied materials contain issues that require 1LINK confirmation: the Payment reserved field is shown as 400 characters in one table but its detailed layout totals 515; the network guideline says private segments only while the kickoff asks for public and private host IPs; and the exact required cipher was supplied only as an unavailable highlighted image. The implementation currently accepts the detailed 515-character Payment layout and a 400-character Inquiry reserved field. These choices must be confirmed in UAT.

Production cutover gates

Gate A - deployment and data safety

- ☐ Take and restore-test a production database backup.
- ☐ Review the change set and deploy it through a controlled release pipeline; this audit did not deploy app.fintap.com.
- ☐ Run the idempotent migration on a production-like clone first, then on production in the approved window.
- ☐ Confirm unique consumer-number and student-sequence migration results.
- ☐ Run database integration tests and an end-to-end invoice, inquiry, payment, duplicate, and reversal/reconciliation scenario.
- ☐ Define an application rollback and a database rollback/forward-fix owner.

Gate B - secrets and runtime configuration

- ☐ Set NODE_ENV=production and REQUIRE_HTTPS=true.
- ☐ Set unique high-entropy JWT and refresh secrets, database credentials, organization webhook secret, and 1LINK credentials through a secret manager.
- ☐ Set FINTECH_PREFIX=105172 for the agreed environment after 1LINK confirms it.
- ☐ Set CORS_ORIGIN to the exact production portal origin.

☐ Set ONELINK_ALLOWED_IPS to the confirmed source/NAT addresses, initially including 10.95.8.92 and 10.95.8.94 only if those are the addresses observed by the application.

☐ Rotate any credentials that have previously appeared in logs, email, source control, screenshots, or test data.

Gate C - network, certificate, and resilience

☐ Provide and confirm Zynotch public/private IPs and separate UAT/Production routes.

☐ Terminate TLS 1.2 or stronger on port 443 with a CA-authorized certificate and full chain; disable obsolete protocols.

☐ Obtain the exact 1LINK cipher-suite name from the referenced screenshot and verify it with an external TLS scan.

☐ Apply network and application allowlists, least-privilege ACLs, static routes, dual connectivity/DR, automatic failover, patched network devices, and the agreed IPsec parameters where applicable.

☐ Confirm app.fintap.com or the selected API hostname resolves to the intended endpoint and forwards X-Forwarded-Proto correctly.

☐ Exercise /api/health and /api/ready through the production load balancer.

Gate D - 1BILL UAT and operations

☐ Exchange credentials only through an approved secure channel.

☐ Prepare all 20 requested consumer cases and obtain 1LINK confirmation of the seven amount slabs.

☐ Complete positive, negative, duplicate, timeout, and retry tests with redacted evidence.

☐ Confirm response-code/HTTP-status handling, time zone, amount units, retry windows, idempotency key, and Payment reserved length.

☐ Establish the SFTP folder, authentication, file schema, naming, encryption, retention, and operational contacts.

☐ Reconcile T+1 settlement to United Bank Limited and document break handling.

☐ Obtain QA/certification approval, production cutover approval, and named owners for at least three days of post-live monitoring.

Residual risks after code remediation

Risk	Current treatment	Required next action
No live/staging database verification	Unit/static gates only	Run disposable-DB integration and migration tests with production-like volume.
No measured 2,000+ performance result	Bounded queries and bulk writes implemented	Load-test at 2,000, 10,000, and expected peak concurrency; record p95/p99 and database plans.

Risk	Current treatment	Required next action
Webhook delivery is not a durable queue	Validation, timeout, and HMAC are present	Add persisted outbox, retry/backoff, dead-letter handling, and replay UI.
SFTP settlement ingestion is outside this application	Handover requirements documented	Build or formally assign settlement file retrieval, validation, reconciliation, alerting, and retention.
API/refresh secrets remain retrievable in current architecture	Rotation and runtime secret guards improved	Move to hashed API keys or encrypted one-time display and hashed refresh-token storage.
DNS may change after webhook validation	DNS resolution blocks local/private targets at validation and send time	For higher assurance, pin resolved public addresses per delivery through a controlled egress proxy.
Financial reversal/refund workflow not certified	Duplicate posting is protected	Agree and implement 1LINK reversal/refund/dispute procedures before enabling them.

Recommended controlled release sequence

1. Freeze schema and API contract changes for the UAT window.
2. Restore a recent sanitized production backup into staging and run migrations.
3. Execute automated gates, database integration tests, and 2,000+/10,000-record load tests.
4. Configure UAT hostname, certificate, firewall/ACLs, credentials, prefix, and source IPs.
5. Execute the formal 1BILL test pack and close every clarification item.
6. Take a fresh backup, deploy during the approved window, run smoke and readiness checks, then enable 1LINK traffic.
7. Reconcile every posting and settlement during the enhanced monitoring period; keep rollback criteria explicit.

Conclusion

The repository is materially safer and more scalable than the reviewed baseline, and its available automated checks pass. It should proceed to controlled staging and 1LINK UAT. It must not be described as production-certified until the database/load tests, infrastructure controls, certificate/cipher validation, consumer test pack, SFTP/reconciliation process, and 1LINK sign-offs are complete.